Ocena bezpieczeństwa usług chmurowych

Materiał edukacyjny do demonstracji. Ogólne zagadnienia bezpieczeństwa informacji.

Zakres materiału

Uogólnione opracowanie edukacyjne do oceny usług chmurowych. Nie jest tekstem normy ISO/IEC 27001 ani opisem architektury, dostawców lub procedur konkretnej organizacji.

Ocena przed rozpoczęciem korzystania

Należy określić cel korzystania z usługi, zakres informacji, wymagania bezpieczeństwa i kryteria wyboru dostawcy. Ryzyko należy ocenić przed przekazaniem danych.

Podział odpowiedzialności

Należy ustalić, które zabezpieczenia zapewnia dostawca, a które użytkownik usługi. Ocena powinna obejmować kontrolę dostępu, konfigurację, monitorowanie i zarządzanie zmianami.

Lokalizacja i podwykonawcy

Należy ustalić miejsca przetwarzania i przechowywania informacji oraz warunki dalszego zlecania przetwarzania. Zmiany lokalizacji lub podwykonawców powinny podlegać uzgodnionemu trybowi powiadamiania i oceny.

Poufność i dostępność

Warunki usługi należy porównać z wymaganiami dotyczącymi poufności, integralności i dostępności danych. Należy ocenić mechanizmy ochrony przed nieuprawnionym dostępem, utratą danych i złośliwym oprogramowaniem.

Reagowanie na incydenty

Należy określić dostępne wsparcie dostawcy, zgłaszanie zdarzeń, współpracę przy wyjaśnianiu ich skutków i gromadzenie dowodów.

Kopie i możliwość wyjścia

Ocena powinna obejmować kopie zapasowe, możliwość odzyskania danych i konfiguracji, bezpieczne usuwanie informacji oraz wsparcie przy zakończeniu korzystania z usługi.

Przegląd warunków

Istotna zmiana usługi, zasad przetwarzania lub warunków umownych może wymagać ponownej oceny. Wynik oceny powinien wskazywać zakres sprawdzenia i nierozstrzygnięte kwestie.